IDOR - SANTA'S LITTLE IDOR

TryHackMe Learning & Practical Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: TryHackMe

Room: IDOR - Santa's Little IDOR (Advent of Cyber 2025)

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

This room is about IDOR (Insecure Direct Object Reference), a broken access control vulnerability. I logged in to the practice application, captured the account request in Burp Suite and used Intruder to change the user_id value and read other users' data.

2. Lab Information

Platform	TryHackMe
Room / Lab	IDOR - Santa's Little IDOR (Advent of Cyber 2025)
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - room questions answered
Link	https://tryhackme.com/room/idor-aoc2025-zl6MywQid9

3. Learning Objectives

- Understand what IDOR is and why it happens.
- Find an object identifier in a request.
- Use Burp Proxy and Intruder to test many identifiers.
- Understand impact and fixes.

4. What is IDOR

IDOR happens when the application uses an identifier from the user (like user_id=10) to fetch data but does not check that the logged-in user is allowed to see that object. Changing the identifier gives access to other people's data (horizontal privilege escalation) or to higher privileges (vertical).

5. Testing Approach

I logged in and saw the account page with children and vouchers. The page loads data from /api/parents/view_accountinfo?user_id=10 with a Bearer token in the Authorization header. I captured the request in Burp Proxy and sent it to Intruder.

I marked the user_id value as the payload position, used a Sniper attack with numbers from 0 to 20 and compared the status code and response length. Most numbers returned 200 with different lengths, which means they returned other users data. I used the response of each id to find the parent with ten children and answer the room question.

6. Evidence

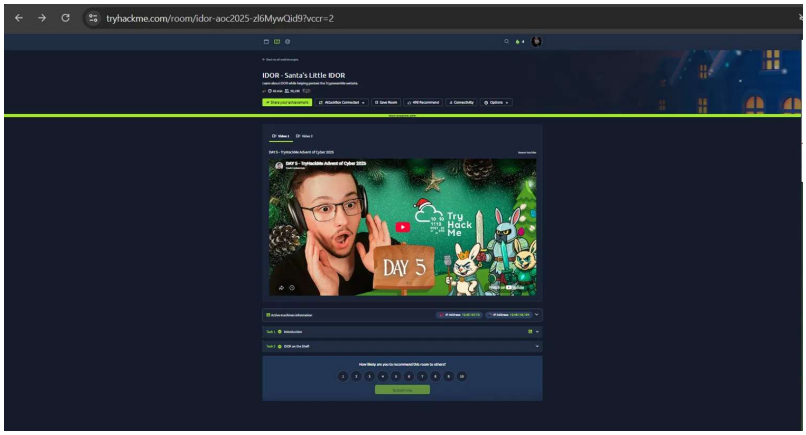


Fig 1 - Room overview (Day 5).

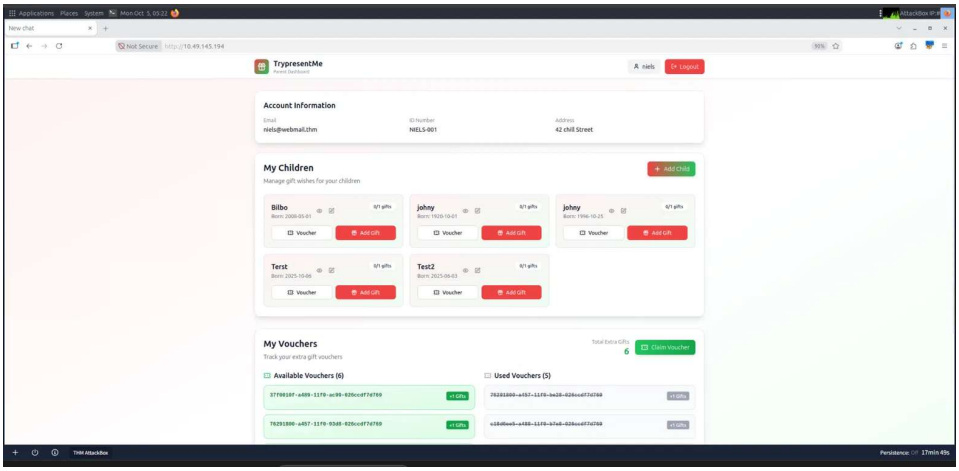


Fig 2 - The application account page.

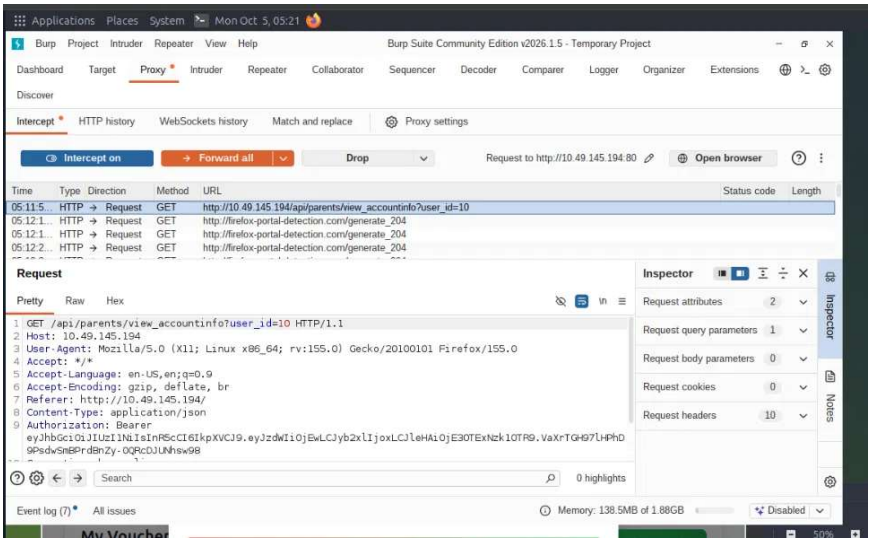


Fig 3 - Request captured in Burp Proxy with user_id=10.

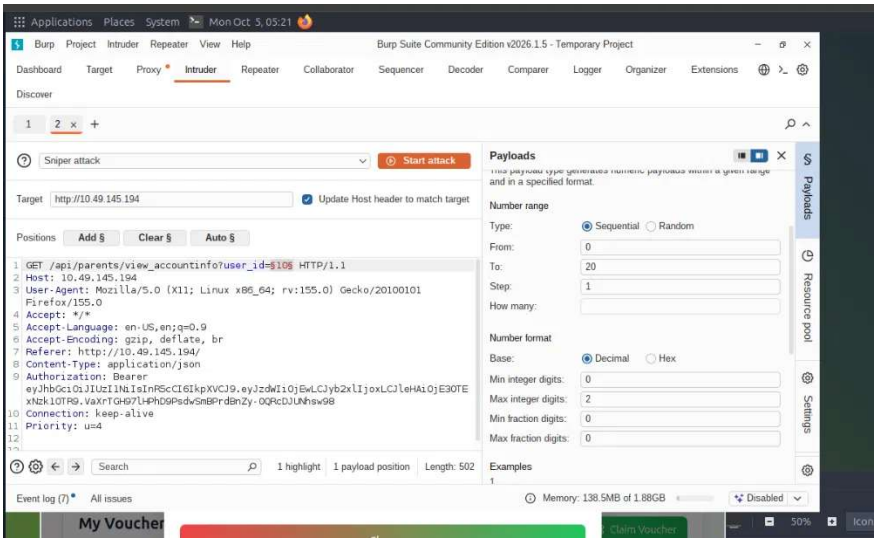


Fig 4 - Intruder sniper attack, numbers 0 to 20.

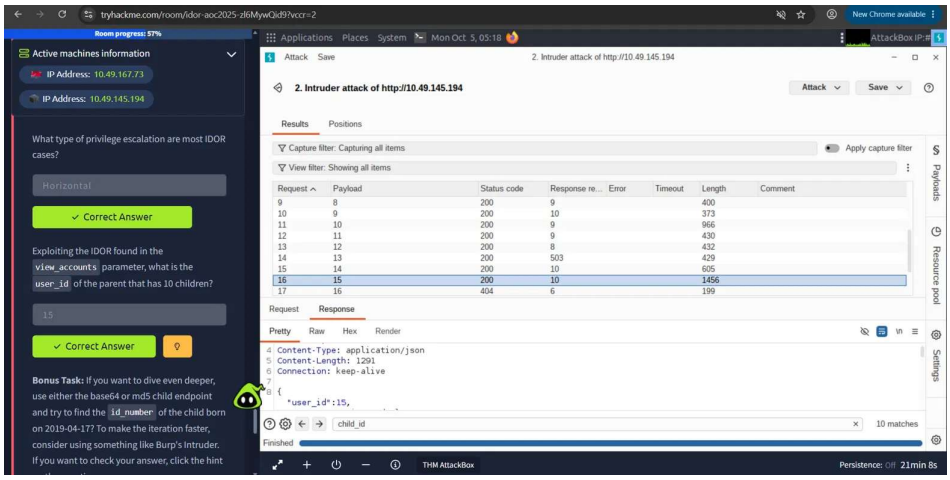


Fig 5 - Intruder results and room answers.

7. Impact

A normal logged-in user can read personal data of other users (names, children, vouchers) only by changing a number. This breaks confidentiality and privacy.

8. Remediation

- Check on the server that the requested object belongs to the logged-in user, for every request.
- Take the user from the session or token and not from a parameter.
- Use random identifiers (UUID) as an extra layer, not as the only protection.
- Add rate limiting and logging to detect enumeration.

9. Key Security Takeaways

- IDOR is easy to find: change an identifier and watch the response.
- Intruder is great for testing many ids, and response length is a good signal.
- Authentication is not authorisation: the token was valid but the ownership check was missing.

10. Skills Practiced

Area	**Practical understanding gained**
Access control	Finding and testing IDOR
Burp Proxy	Capturing authenticated API requests
Burp Intruder	Sniper attack with numeric payloads
Analysis	Comparing status codes and response lengths

11. What I Would Explore Next

I want to test IDOR in POST/PUT requests and with encoded identifiers (base64, hashes) and learn more about broken access control.

12. Conclusion

IDOR showed me that a simple missing check can expose many users' data. It is one of the easiest bugs to test, so I will always try changing identifiers in my tests.

Completion status: Completed - room questions answered.

13. References

TryHackMe: https://tryhackme.com/room/idor-aoc2025-zl6MywQid9